

Legal & IP 私有雲治理平台建置

Knowledge × IP × Compliance × AI Governance |
以 私有雲打造法律知識治理中台

講者：施宇芳 Annie Shih
法務長暨智慧財產主管，QNAP Systems, Inc.

日期：2026 年 7 月 1 日
雲端大會 Cloud Summit



施宇芳 Annie Shih

QNAP Systems, Inc.
法務長暨智慧財產主管

專長：

跨國營運、AI / 雲端法遵策略、資料治理、資安與智慧財產佈局。推動企業於數位轉型與 AI 發展過程中的法律治理架構。

經歷：

- Delta Electronics
- HTC
- HP
- 台灣大學 法律學系 (台灣律師)
- Univ. of Pennsylvania LL.M.

Legal & IP 面臨的四大治理挑戰：

1



資訊碎片化：
散落於 email、個人硬碟、
雲端，版本零控管。

2



AI 失控風險：
外部雲端 AI (如 ChatGPT)
導致機密外洩與 RAG 失控。

3



法遵追蹤斷鏈：
缺乏完整法遵證據鏈
(CRA / GDPR / PFAS)。

4



組織知識流失：
高度依賴特定人員，異動
導致知識斷層與重工。



核心痛點：現有工具只是「儲存工具」，我們需要的是知識 × IP × 法遵 × AI 的一體化「治理工具」。

以法規及國際標準為基礎落實企業私有雲治理

Legal & IP Assets

Pillar 1:
[ISO 27001 / 27701]
資訊安全與
隱私管理
(存取控制、加密、
事件回應)

Pillar 2:
[ISO 30401]
知識管理
(KM 政策、
知識創建 / 保存)

Pillar 3:
[ISO 42001 / 23894]
AI 管理系統與
風險評估
(RAG 邊界、
模型引入)

Pillar 4:
[NIST CSF 2.0]
網路安全框架
(識別→保護→偵測
→回應→復原)

Pillar 5:
[TIPS]
台灣智慧財產權
管理制度(營業秘密、
專利、著作權、商標)

由底到頂的六層私有雲治理架構

第六層 安全控制 & 稽核

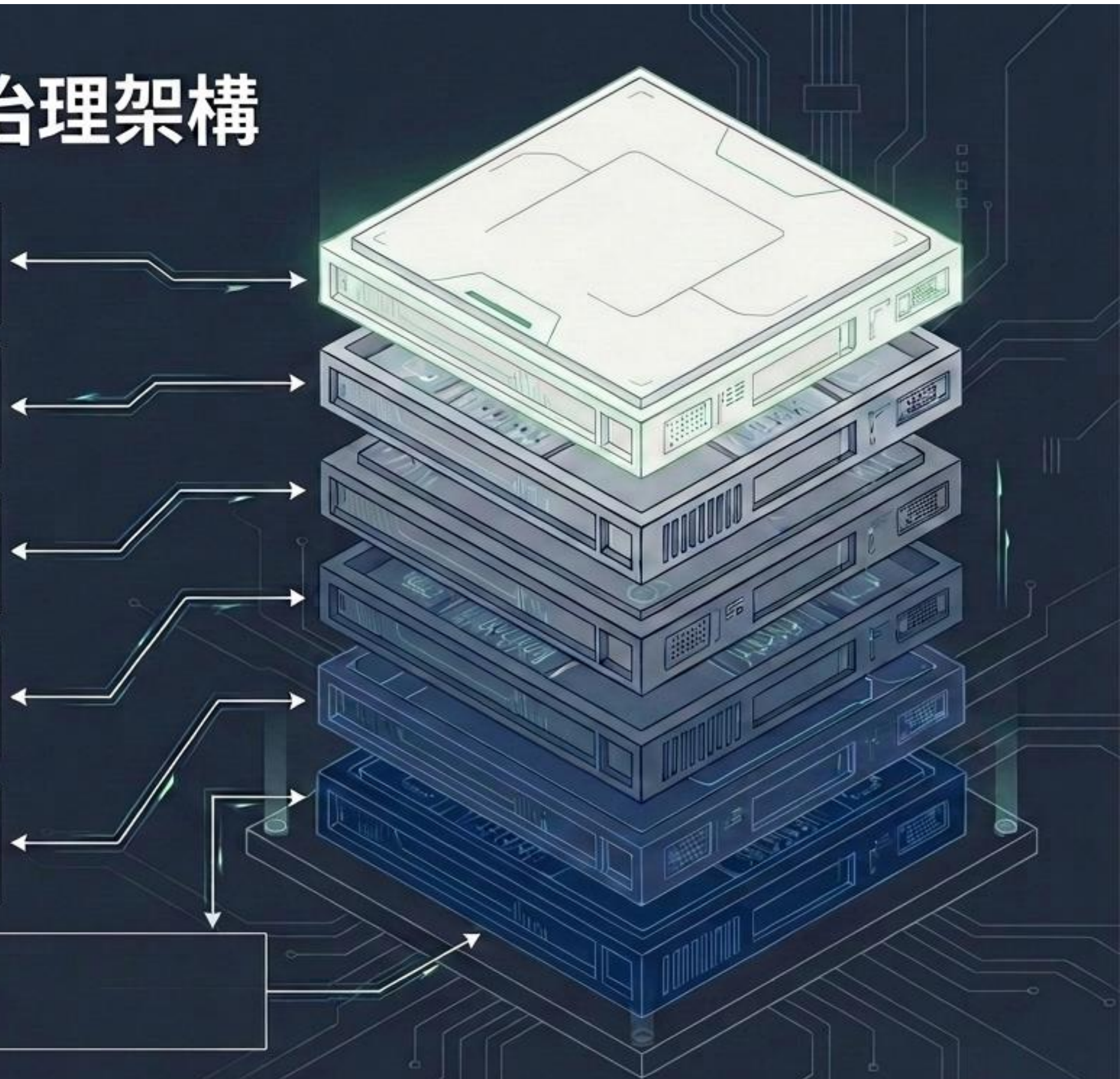
第五層 AI / RAG 治理

第四層 文件 & 證據

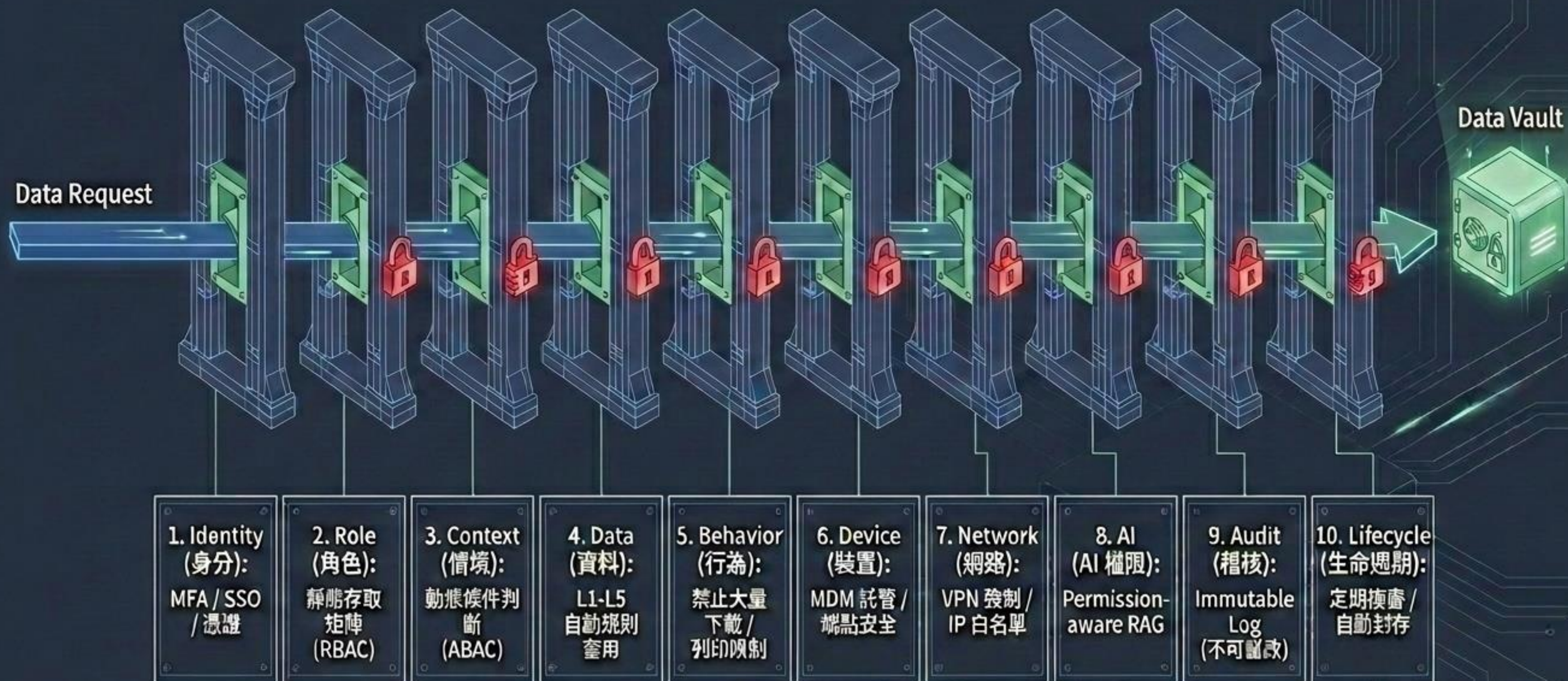
第三層 Legal & IP 應用

第二層 資料分級 & 存取

第一層 身分 & 基礎建設



以嚴謹之治理架構落實AI Readiness的企業資料倉儲



圖下方備注：L1到L10之做法依據實際個案可能出現差異

身份認證、RBAC、ABAC重要但不足夠：不只是進門而是進門後發生什麼？

RBAC (角色型，Role-Based Access Control)：

	L5 存取	L4 存取	L3 存取	L2 存取	L1 存取
法務主管	✓	✓	✓	✓	✓
IP Manager	✗	✓	✓	✓	✓

靜態矩陣。例如：法務主管可存取 L5，IP Manager 存取 L4。

ABAC (屬性型，Attribute-Based Access Control)：



動態情境判斷。

- ⚙️ 狀態：當文件標示 Legal Hold → 立即鎖定禁止刪除。
- 🕒 時間：外部顧問 (External Counsel) → 期限後自動撤銷。
- 📱 裝置：若為非託管裝置 → 降級存取權限。
- 🌐 地區：GDPR 資料 → 限制於 EU 伺服器。

資料分級框架：按敏感度決定 AI 邊界



關鍵補充控制 (實戰應用)



操作限制 & DLP 防護

- 停用右鍵複製/貼上；>5 檔/10 分鐘觸發大量下載警示；批次列印需 L3+ 審批。



- L4+ 文件自動套用浮水印 (姓名+時間戳)；攔截雲端同步 (Google Drive) 與 Email 附件外傳。



設備與網路

- 非託管裝置直接拒絕或降級唯讀；
- 強制 VPN (L3+ 必須)；
- 異地登入即時警示。



生命週期

- 外部顧問 30-90 天權限自動歸零；
- Legal Hold 狀態優先保留，覆蓋自動刪除。

AI 三池治理：邊界清楚，可稽核



 **限制池 (Restricted Pool)：**
L4-L5 資料 (訴訟策略 / 核心 IP / 未公告專利)。完全禁止 AI 存取，Legal Hold 鎖定。



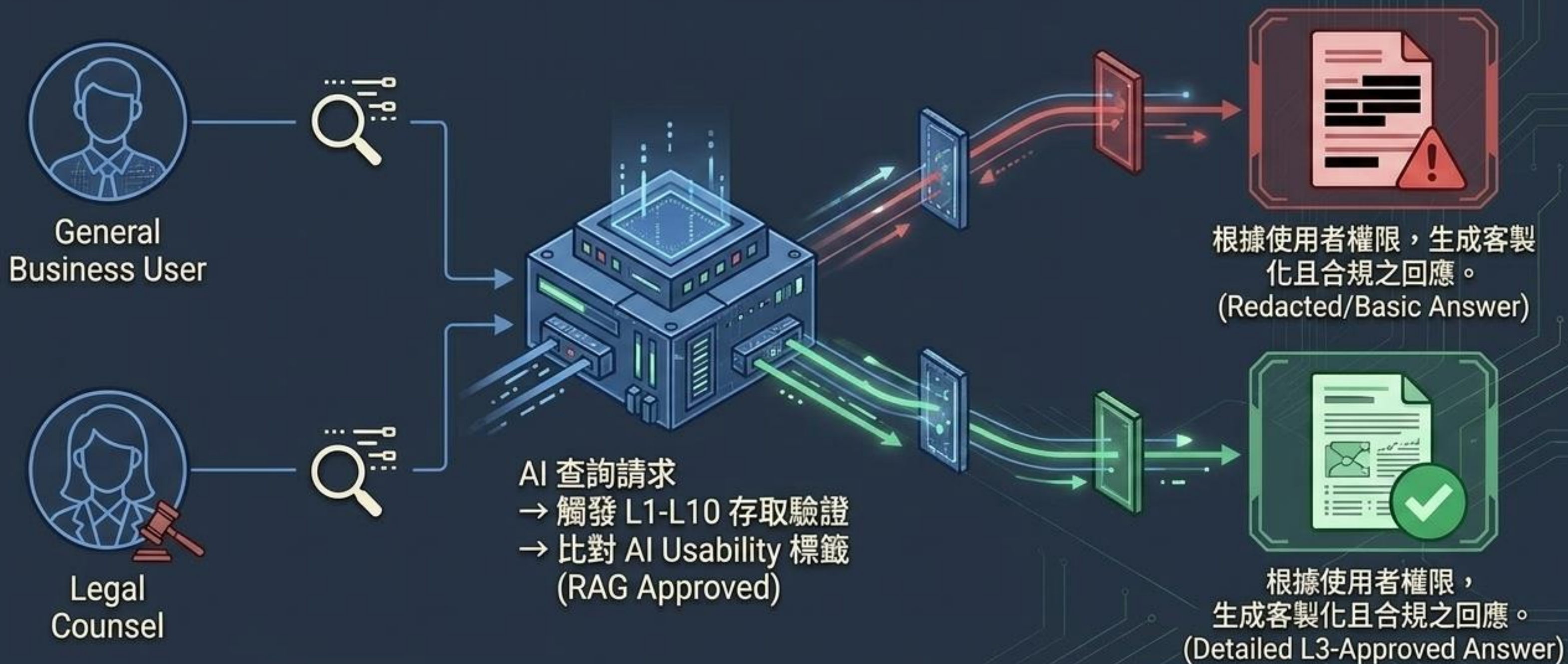
 **核准知識池 (Approved Pool)：**
L3 資料 (核准合約條款 / 判例)。RAG 可存取，回應可稽核回溯。



 **參考池 (Reference Pool)：**
L1-L2 資料 (公開法規 / 標準)。AI 可參考，需標示來源。

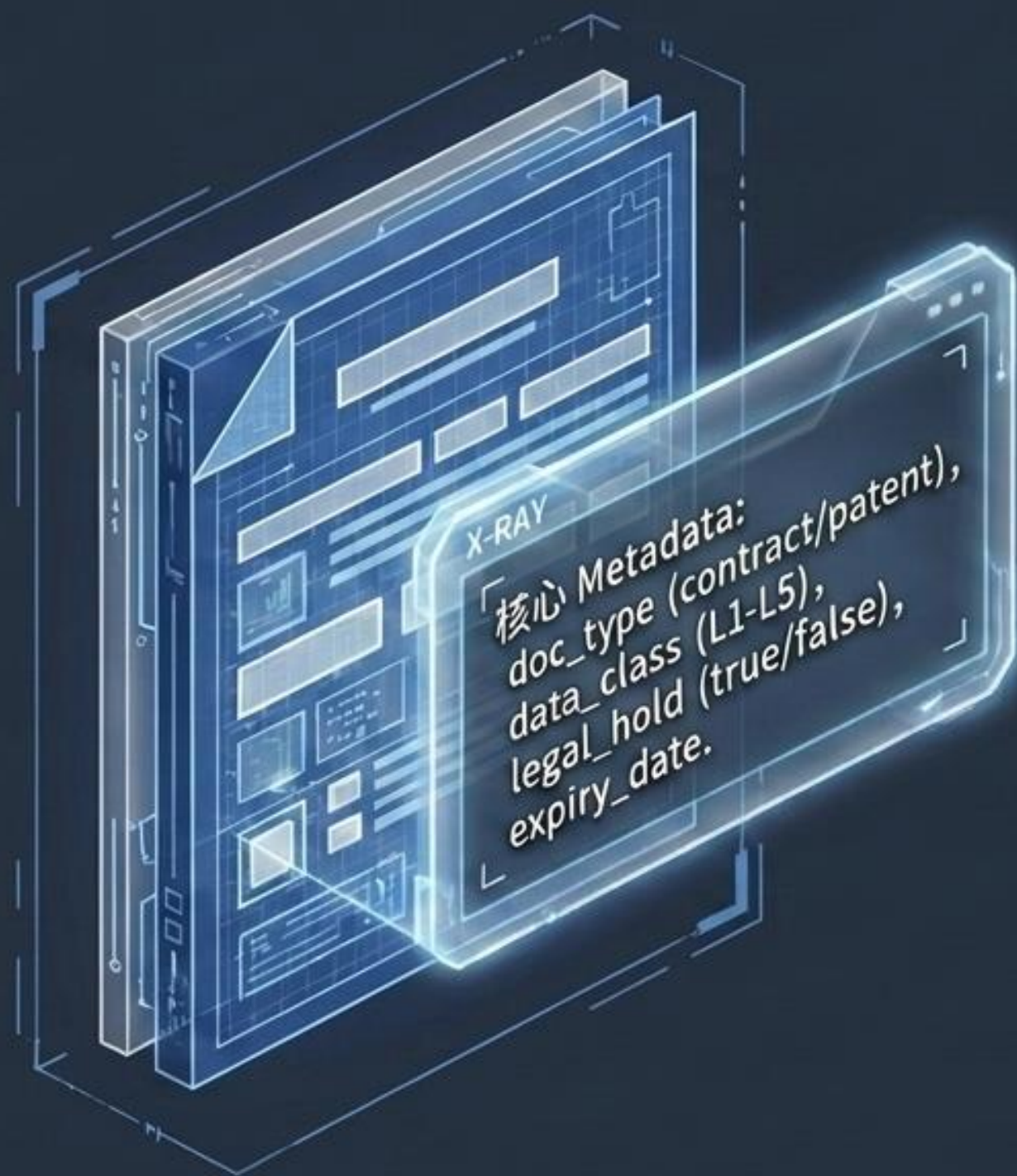
治理四要求：可稽核 (Auditable) | 可解釋 (Explainable) | 邊界明確 (Bounded) | 人工審核 (Human-in-Loop)

Permission-Aware RAG：AI 不能超越使用者權限



「使用者不能看的，AI 也絕對不能拿來回答。」

目標：讓每份文件具備AI Readiness的治理屬性



No AI Use: 完全禁止所有 AI 功能。



Searchable Only: 僅允許全文搜尋。



Summary Only: 允許生成摘要，不允許 RAG。



RAG Approved: 可進入核准 RAG 知識池。



External Response OK: 可作為對外 AI 回應來源。

重要應用：三大核心工作流程之標準化與可追蹤

合約生命週期 (CLM)

需求申請

草稿建立

法務審閱

業務核准

電子簽章

歸檔

到期警示

IP 申請 & 授權管理

IP 識別

可專利性
分析

申請提交

審查追蹤

核准存檔

授權管理
與維護

法規追蹤 & 法遵

法規監控

影響評估

任務指派

執行記錄

稽核證據

年度複查

四階段藍圖：從底座到全治理中台



建構AI Readiness的 企業私有雲是最好的ESG

Thank you. Q&A